

RADIUS AAA Server

Introduzione

RADIUS (Remote Authentication Dial-In User Service) è uno dei protocolli AAA (Authentication, Authorization, Accounting) più diffusi nelle infrastrutture di rete moderne.

Viene utilizzato per centralizzare il controllo degli accessi alla rete in ambienti:

- aziendali
- universitari
- ISP
- reti Wi-Fi enterprise
- VPN
- infrastrutture NAC

In una rete molto piccola il controllo degli accessi può essere gestito direttamente nei dispositivi di rete.

Ad esempio:

- password Wi-Fi condivisa
- utenti locali sul router
- ACL configurate manualmente

Questo approccio però diventa rapidamente ingestibile quando:

- aumentano gli utenti
- aumentano gli apparati
- aumentano sedi e VLAN
- servono policy differenziate

RADIUS consente quindi di centralizzare autenticazione, autorizzazione e accounting.

Il modello AAA

AAA significa:

- Authentication
- Authorization
- Accounting

Authentication

L'autenticazione consiste nella verifica dell'identità di un utente oppure di un dispositivo.

L'utente deve dimostrare di essere realmente chi dichiara di essere.

I meccanismi di autenticazione possono includere:

- username e password
- certificati digitali
- smart card
- token OTP
- autenticazione multifattore

In molti ambienti enterprise può essere autenticato anche il dispositivo.

Esempio:

- notebook aziendale con certificato macchina
- smartphone gestito tramite MDM

Authorization

Dopo l'autenticazione il sistema deve decidere cosa l'utente può fare.

Il server RADIUS può restituire:

- VLAN dinamica
- ACL
- limiti di banda
- timeout sessione
- privilegi specifici

Esempio:

- studenti → solo Internet
- docenti → server interni
- amministratori → dispositivi di rete

Accounting

L'accounting consiste nella registrazione delle informazioni relative alle sessioni di rete.

Possono essere registrati:

- orario di accesso
- durata sessione
- traffico generato
- IP assegnato
- disconnessione

Questi dati possono essere utilizzati per:

- audit di sicurezza
 - monitoraggio
 - troubleshooting
 - conformità normativa
 - tracciabilità degli accessi
-

Componenti coinvolti

In un sistema RADIUS tipico entrano in gioco:

- client/supplicant
- NAS
- server RADIUS

Supplicant

È il dispositivo dell'utente:

- PC
- smartphone
- tablet
- notebook

NAS

NAS significa:

Network Access Server

Non deve essere confuso con:

Network Attached Storage.

Il NAS è normalmente:

- access point
- switch
- concentratore VPN
- firewall

Il NAS:

- controlla fisicamente l'accesso alla rete
- applica le decisioni del server RADIUS
- inoltra le richieste AAA

Il NAS non verifica direttamente le credenziali.

Server RADIUS

Il server RADIUS:

- verifica le credenziali
 - decide autorizzazioni
 - registra accounting
 - può interrogare directory esterne
-

Relazione tra 802.1X, EAP e RADIUS

Nelle reti enterprise RADIUS viene normalmente utilizzato insieme a IEEE 802.1X.

Il modello 802.1X prevede:

- supplicant
- authenticator
- authentication server

L'autenticator è normalmente:

- switch
- access point

Il client comunica inizialmente tramite:

EAPOL (EAP over LAN)

L'access point o switch incapsula poi i messaggi EAP nel protocollo RADIUS.

Metodi comuni

Tra i metodi più diffusi:

- PAP
- CHAP
- EAP
- PEAP
- EAP-TLS
- EAP-TTLS

WPA Personal vs WPA Enterprise

In reti domestiche viene spesso utilizzato:

- WPA2/WPA3 Personal

con password condivisa.

Nelle reti enterprise si utilizza invece:

- WPA2/WPA3 Enterprise

con autenticazione individuale tramite RADIUS.

Flusso di autenticazione

Scenario tipico Wi-Fi enterprise:

1. Il client tenta la connessione.
2. L'access point blocca temporaneamente il traffico.
3. Il client invia informazioni di autenticazione.
4. L'AP inoltra i messaggi al server RADIUS.
5. Il server verifica credenziali e policy.
6. Il server restituisce Access-Accept oppure Access-Reject.
7. Il NAS applica eventuali VLAN o ACL.
8. Il client ottiene accesso alla rete.

È importante osservare che:

- spesso la password non viene inoltrata in chiaro
 - vengono trasportati messaggi EAP
 - PEAP/TLS utilizzano tunnel protetti
-

Porte e protocolli

RADIUS utilizza principalmente UDP.

Non utilizza normalmente TCP.

Porte standard:

- UDP 1812 → autenticazione
- UDP 1813 → accounting

Porte storiche:

- UDP 1645
 - UDP 1646
-

Sicurezza del protocollo

Storicamente RADIUS non cifra completamente tutto il traffico AAA.

Per questo motivo viene spesso utilizzato insieme a:

- EAP protetti
- PEAP

- TLS
- reti interne sicure
- VPN

DIAMETER è stato progettato come evoluzione più moderna del protocollo.

Introduce:

- maggiore affidabilità
- trasporto più moderno
- migliore gestione failover
- sicurezza migliorata

Nonostante questo, RADIUS rimane estremamente diffuso.

Integrazione con Active Directory

RADIUS e Active Directory svolgono ruoli diversi.

Active Directory

Active Directory è:

- directory centralizzata
- gestione utenti e gruppi
- autenticazione Kerberos
- gestione dominio Windows

RADIUS

RADIUS è:

- protocollo AAA
- controllo accessi rete
- autorizzazione centralizzata

Molto spesso il server RADIUS utilizza Active Directory come backend.

FreeRADIUS può:

- interrogare LDAP
- usare Kerberos
- utilizzare NTLM/MSCHAP
- verificare password contro Active Directory

Questo permette Single Sign-On e credenziali centralizzate.

Esempi di server RADIUS

FreeRADIUS

Server open source molto diffuso.

Utilizzato in:

- università
- ISP
- aziende
- laboratori

Supporta:

- LDAP
- Active Directory
- SQL
- EAP
- accounting avanzato

Microsoft NPS

Integrato in Windows Server.

Molto usato in ambienti Active Directory.

Cisco ISE

Piattaforma enterprise avanzata.

Integra:

- AAA
- NAC
- posture assessment
- profiling dispositivi

Installazione FreeRADIUS su Ubuntu

Aggiornare repository:

```
sudo apt update
```

Installare:

```
sudo apt install freeradius
```

Avviare servizio:

```
sudo systemctl start freeradius
```

Verificare stato:

```
sudo systemctl status freeradius
```

Abilitare avvio automatico:

```
sudo systemctl enable freeradius
```

Modalità debug

La modalità debug è fondamentale durante:

- configurazione
- troubleshooting
- laboratorio
- studio protocollo

Comando:

```
sudo freeradius -X
```

La console mostra:

- richieste Access-Request
- verifica utenti
- autenticazione
- Access-Accept
- Access-Reject
- moduli utilizzati

In produzione normalmente non si utilizza la modalità debug.

LAB 1 – Osservare autenticazione RADIUS

Installare strumenti:

```
sudo apt install freeradius-utils
```

Avviare FreeRADIUS in debug:

```
sudo freeradius -X
```

In altro terminale:

```
radtest testuser password123 localhost 0 testing123
```

Osservare:

- ricezione richiesta
- verifica utente
- controllo password

- risposta AAA
-

LAB 2 – Utenti locali

Nelle installazioni Debian/Ubuntu il file utenti si trova normalmente in:

`/etc/freeradius/3.0/users`

oppure internamente:

`mods-config/files/authorize`

Aggiungere:

```
studente1 Cleartext-Password := "1234"
```

```
studente2 Cleartext-Password := "abcd"
```

Test:

```
radtest studente1 1234 localhost 0 testing123
```

FreeRADIUS con Docker

Riferimenti ufficiali

Docker Hub:

<https://hub.docker.com/r/freeradius/freeradius-server/>

GitHub:

<https://github.com/FreeRADIUS/freeradius-server>

Documentazione Docker LDAP:

https://www.freeradius.org/documentation/freeradius-server/4.0.0/howto/modules/ldap/bootstrap_openldap/docker.html

Prerequisiti Docker

Installare Docker Desktop oppure Docker Engine.

Verificare:

```
docker --version
```

```
docker compose version
```

Struttura directory

Creare:

```
freeradius-docker/  
  Dockerfile  
  raddb/  
    clients.conf  
    mods-config/  
      files/  
        authorize
```

Dockerfile

Contenuto:

```
FROM freeradius/freeradius-server:latest  
COPY raddb/ /etc/raddb/
```

clients.conf

Configurazione minima:

```
client dockernet {  
  ipaddr = 172.17.0.0/16  
  secret = testing123  
}
```

Configurazione localhost:

```
client localhost {  
  ipaddr = 127.0.0.1  
  secret = testing123  
}
```

In produzione:

- limitare IP
 - utilizzare secret robusti
-

authorize

Inserire utenti:

```
bob    Cleartext-Password := "test"  
alice  Cleartext-Password := "alice123"
```

```
mario Cleartext-Password := "mario123"
```

Build immagine

Eseguire:

```
docker build -t my-radius-image -f Dockerfile .
```

Avvio container

Modalità normale:

```
docker run --rm -d --name my-radius \
  -p 1812:1812/udp \
  -p 1813:1813/udp \
  my-radius-image
```

Modalità debug:

```
docker run --rm --name my-radius -t \
  -p 1812:1812/udp \
  -p 1813:1813/udp \
  my-radius-image -X
```

Test autenticazione

Installare strumenti FreeRADIUS oppure usare WSL.

Test:

```
radtest bob test 127.0.0.1 0 testing123
```

Risposta attesa:

```
Access-Accept
```

Cosa osservare nel debug

Verificare:

- Access-Request
- identificazione client
- lookup utente
- verifica password
- Access-Accept

- Access-Reject
-

Variante Alpine

Dockerfile:

```
FROM freeradius/freeradius-server:latest-3.2-alpine
COPY raddb/ /etc/raddb/
```

Le immagini Alpine:

- sono più leggere
 - possono non includere tutti i moduli
 - richiedono librerie aggiuntive
-

Bind mount configurazione

Per evitare rebuild continui:

```
docker run --rm --name my-radius -t \
  -p 1812:1812/udp \
  -p 1813:1813/udp \
  -v ${PWD}/raddb:/etc/raddb \
  freeradius/freeradius-server:latest -X
```

Docker Compose

compose.yaml:

```
services:
  freeradius:
    image: my-radius-image
    container_name: my-radius
    ports:
      - "1812:1812/udp"
      - "1813:1813/udp"
    command: ["-X"]
```

Avvio:

```
docker compose up
```

LDAP in Docker

La documentazione ufficiale mostra anche integrazione con:

- OpenLDAP
- container LDAP
- schema FreeRADIUS
- dati test

Questo permette:

- autenticazione centralizzata
 - gestione utenti directory
 - integrazione enterprise
-

Errori comuni

Client non definito

Se manca clients.conf:

- FreeRADIUS rifiuta richieste
- il NAS non viene considerato affidabile

Secret errato

Il secret deve coincidere:

- nel client
- in radtest
- in clients.conf

Mancato debug

La modalità -X è quasi indispensabile in laboratorio.

Certificati self-signed

I certificati inclusi di default:

- sono solo per laboratorio
 - non devono essere usati in produzione
-

Setup minimo completo

Dockerfile:

```

FROM freeradius/freeradius-server:latest
COPY raddb/ /etc/raddb/

clients.conf:

client localhost {
    ipaddr = 127.0.0.1
    secret = testing123
}

client dockernet {
    ipaddr = 172.17.0.0/16
    secret = testing123
}

authorize:

bob    Cleartext-Password := "test"
alice  Cleartext-Password := "alice123"

Build:

docker build -t my-radius-image -f Dockerfile .

Run:

docker run --rm --name my-radius -t \
    -p 1812:1812/udp \
    -p 1813:1813/udp \
    my-radius-image -X

Test:

radtest bob test 127.0.0.1 0 testing123

```

Quando usare questo setup

Questo setup è adatto per:

- laboratori
- studio protocollo
- AAA base
- test VPN
- 802.1X
- simulazioni NAC

In produzione normalmente si utilizzano:

- LDAP
- Active Directory
- SQL

- certificati enterprise
 - alta affidabilità
-

Conclusione

RADIUS rappresenta uno dei pilastri dell'autenticazione nelle reti moderne.

Attraverso AAA permette:

- autenticazione centralizzata
- autorizzazione dinamica
- accounting
- controllo accessi
- integrazione enterprise

La sua integrazione con:

- Active Directory
- LDAP
- VPN
- NAC
- Wi-Fi enterprise

lo rende fondamentale nelle infrastrutture professionali moderne.

Nonostante esistano protocolli più moderni come DIAMETER, RADIUS continua a essere estremamente diffuso grazie alla semplicità, interoperabilità e ampio supporto da parte dei produttori di rete.